

Operational Policy

Policy title:	Information Technology Vulnerability Management Policy		
Policy number:	ODHSOHA 090-007		
Original date:	06/05/2017	Last update:	08/01/2025
Approved:	Kris Kautz, OHA Seth Lyon, ODHS		

Purpose

The Office of Information Services (OIS) is committed to implementing and maintaining a vulnerability management program for the Oregon Department of Human Services (ODHS) and the Oregon Health Authority (OHA) that protects information assets and systems, mitigates vulnerabilities, and reduces the risk of malicious activity. This policy applies to all software and systems including third party applications, operating systems, and any other systems not developed internally.

Description

This policy applies to all information systems and applications of ODHS and OHA. This policy outlines the implementation and maintenance of comprehensive, integrated information security techniques designed to proactively identify and report the exploitation of vulnerabilities through a collaborative, systematic, accountable, and documented process.

Applicability

This policy applies to OIS, ODHS and OHA information system owners, and external vendors.

As keepers of the public trust, all agency employees have a responsibility to comply with state and agency policies, administrative rule, and state and federal law. The agency takes this responsibility seriously and failure to fulfill this responsibility is not treated lightly. Employees who fail to comply with state or agency policy, administrative rule, or state and federal law may face progressive discipline, up to and including dismissal from state service.

Policy

1. Vulnerabilities are weaknesses in information technology (IT) systems, software, system security procedures, and internal controls that can be exploited by a cybersecurity threat source.¹
2. To address security vulnerabilities, the Office of Information Services (OIS) shall run automated vulnerability scans of assets on all ODHS and OHA information systems and applications using a Security Content Automation Protocol (SCAP) compliant vulnerability scanning tool provided internally or by Enterprise Information Services (EIS).
 - a. Internal and external vulnerability scans shall be performed at least monthly using authenticated and unauthenticated scanning tools.²
 - b. For systems that are not managed by the agency, the external vendors shall be required to prove ongoing vulnerability scans are completed.
3. Vulnerability scans of information systems and applications shall be performed based on best practice and statutory or regulatory requirements. Scans shall also be performed:
 - a. Whenever significant changes are made to the environment, including additions, modifications, and upgrades of infrastructure, applications, websites, or other conditions that may affect the security of the system.
 - b. Before new systems and applications are added to the network.
 - c. At the discretion of the EIS Cyber Security Services (EIS CSS) or the agency Chief Information Risk Officer (CIRO).
4. The Information Security and Privacy Office (ISPO) shall establish, maintain, document, and review a risk-based remediation strategy at least monthly.
5. OIS, information system owners, EIS CSS, and EIS Data Center Services (DCS), shall ensure:
 - a. All patches³ are evaluated for risk and impact to ODHS and OHA.
 - b. Software and operating system vulnerabilities are remediated through automated patch management at least monthly.
 - c. Remediated vulnerabilities are retested to verify patches and other mitigations were effective.
6. Agency issued mobile devices, desktops, laptops, and tablets that have not received required patches through OIS shall be evaluated by ISPO in coordination

¹ National institutes of Standards and Technology (NIST) Special Publication (SP) 800-53 Revision 5

² Center for Internet Security (CIS) Controls version 8, 7.5, 7.6; Statewide Information Technology Control Standards Risk Assessment (RA)-5

³ Committee on National Security Systems (CNSS) Glossary

with OIS Technology Engineering, Development, and Support (TEDS), and as appropriate, other information system owners.

7. When vulnerabilities are identified and cannot be remediated, a risk determination will be made using the Continuous Vulnerability Management Process (090-07-01).

References

[Committee on National Security Systems \(CNSS\) Glossary](#)
[Microsoft SecurityTech Center Security Bulletin Severity Rating System, GG309177](#)
[National Institute of Standards and Technology \(NIST\) 800-30 Rev. 1 Guide for Conducting Risk Assessments](#)
[NIST SP 800-40 Rev. 4 Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology](#)
[NIST SP 800-53 Rev. 5 Security and Privacy Controls for Information Systems and Organizations](#)
[NIST SP 800-61 Rev. 2 Computer Security Incident Handling Guide](#)
[NIST SP 800-115 Technical Guide to Information Security Testing and Assessment](#)
[NIST SP 800-137 Information Security Continuous Monitoring \(ISCM\) for Federal Information Systems and Organizations](#)
[NIST Internal Report \(IR\) Common Vulnerability Scoring System \(CVSS\) Implementation Guidance 7946](#)
[ODHSOHA 090-006-01 Information Security Risk Assessment Process](#)
[ODHSOHA 090-006-02 Information Security Risk Assessment Process Map](#)
[ODHSOHA 090-006-03 Continuous Vulnerability Management Process](#)
[ODHSOHA 090-006-04 Continuous Vulnerability Management Process Map](#)
[45 CFR 164 Security and Privacy](#)
[Oregon Administrative Rules \(OAR\) 125-055-0100 to 125-055-0130 State Purchasing](#)
[OAR 943-014-0400 to 943-014-0465 Privacy and Confidentiality](#)
[Oregon Revised Statute \(ORS\) 192.355 Public Records Exempt from Disclosure](#)
[Criminal Justice Information Services \(CJIS\) Security Policy](#)
[Federal Information Processing Standards \(FIPS\) Publication \(Pub\) 199 Standards for Security Categorization of Federal Information and Information Systems](#)
[Gartner, Improve IT Security with Vulnerability Management, G00127481](#)
[Acceptable Risk Controls for Affordable Care Act for Medicaid Partner Exchanges](#)
[Social Security Administration Information Exchange Security Requirements and Procedures](#)
[Statewide Information Security Program Plan](#)
[Statewide Information Technology Control Standards](#)
[Statewide Standards Alignment with CIS Security Standards](#)
[Center for Internet Security \(CIS\) Controls](#)

Related policies

[DAS 107-004-052 Cyber and Information Security](#)

[DAS 107-004-120 Cyber and Information Security Incident Response](#)
[ODHSOHA 070-015 Information Technology Change Management Policy](#)
[ODHSOHA 090-005 Information Security Incident Management](#)
[ODHSOHA 090-006 Information Security Risk Assessment Policy](#)
[OHA 100-014 Report and Response to Privacy and Security Incidents](#)

This policy will be reviewed at least once every year to ensure relevance.

Contact

Office of Information Services
Service Desk: 503-945-5623
OIS.ServiceDesk@odhsoha.oregon.gov

Policy history

Version 1 DHSOHA-090-007 established 06/05/2017
Version 2 Revised 05/07/2018
Version 3 Revised 06/07/2021
Version 4 Revised 06/05/2023
Version 5 Revised 04/15/2025
Version 6 Revised 08/01/2025

Keywords

Maintenance, mitigation, patch, remediation, security

This document can be provided upon request in an alternate format for individuals with disabilities or in a language other than English for people with limited English skills. To request this document in another format or language, contact the Publications and Design Section at 503-378-3486, 7-1-1 for TTY, or email dhs-oha.publicationrequest@odhsoha.oregon.gov